LAB 3 | Threat & Risk Register

Çıktı: Gerekçeli ve sıralanmış Risk Register · **EP 04** · T01/T02 s.4; T03 s.23–33, 43–46

Değerlendirme tarihi 26.10.2026; hazırlayan Batuhan Yaşar Özkan; makine modeli Arminoks Süt Otomatı eğitim modeli v1.0. Gerçek konfigürasyon sürümü bilinmez. Başlangıç, V01–V09 kabulleridir; H hedef kontroller uygulanmış sayılmaz. Mevcut kontrol kanıtı olmadığından puanlar saha bulgusu değil, koşullu eğitim değerlendirmesidir.

Ölçek: L × S × E

Puan	L: kapının istismar edilebilirliği	S: fiziksel sonuç	E: yolun dışarıya açıklığı
1	Zor; özel bilgi/fiziksel erişim veya zincir gerekir	Yaralanma yok; kalite/üretim/ekipman etkisi	Yalnız makine başında fiziksel erişim
2	Orta; zayıf/paylaşılan kimlik bilgisi gerekir	Hafif, geri dönüşlü yaralanma	İşletme ağı veya süreli kontrollü dış erişim
3	Kolay; doğrulama yok/varsayılan, hazır araçla erişim	Ağır/kalıcı yaralanma, ölüm, yangın/patlama	Doğrudan internet veya sürekli açık dış yol

E, insan maruziyeti değildir. Bantlar: 18–27 Kritik; 9–17 Yüksek; 4–8 Orta; 1–3 Düşük. Her S3 ayrı listelenir; en az bir önlem veya yetkili yazılı kabul olmadan kapatılmaz (T03 s.29). Puan yalnız ölçek ve varsayımla anlamlıdır.

Görev: senaryoları kurun ve puanlayın

Föydeki üç senaryo koşulu aşılmış; T03'ün en az üç profil ve beş kapı koşulu, dört profil ve LAB2 G01–G06 envanteriyle karşılanmıştır. Aşağıdaki senaryolar işletilebilir saldırı talimatı değil, savunma amaçlı neden-sonuç modelleridir.

R-01 | Fırsatçı dış: uzaktan koruma mantığının değiştirilmesi

Fırsatçı dış saldırgan, **G01** uzak servis yolundan (V05/V06) bakım istasyonuna ve **G05** normal kontrol programlama yoluna erişir; V08'deki kapak/yeniden başlama mantığını değiştirir. **SF-01/SF-03** bozulur; V02'de bakım yapan kişi erişirken karıştırıcı beklenmedik çalışır ve el/kol ağır yaralanabilir. Bağ: Z0→Z2→Z3→Z4; C01/C02/C03; A02/A03/A07/A08/U03.

L3: Başlangıç varsayımında değiştirilmemiş varsayılan kimlik bilgisi ve sınırsız yazma vardır. S3: Erişilebilir hareketli parçaya yakalanma ağır/kalıcı yaralanmayla sonuçlanabilir. E3: G01 eğitimde sürekli açık dış bağlantıdır. Fiziksel erişimin bakım sırasında gerçekleşmesi ayrıca V02'dir; E puanının tanımı değiştirilmez.

R-02 | Meraklı içeriden: sıcaklık kontrolünün gevşetilmesi

Meraklı içeriden kişi, **G02** yerel paylaşılan servis hesabıyla sıcaklık veya satış engelleme koşulunu değiştirir (V04/V07). **SF-02** etkisizleşir; uzunluğu ve koşulları belirsiz uygunsuz muhafaza sonrasında ürün satılırsa tüketiciye ciddi biyolojik zarar oluşabilir. Bu zincir, gerçek bulaşma veya hastalık bulgusu değildir. Bağ: Z4; A01/A04/U02/F01.

L2: Paylaşılan fakat bilinmesi gereken servis kimlik bilgisi kabul edilir. S3: Koşullu en kötü fiziksel sonuç ciddi hastalıktır; tek sıcaklık sapmasının hastalık yaptığı varsayılmaz. E1: Bu senaryonun giriş yolu yalnız makine başındaki ekrandır. Uzaktan panel erişimi varsa yeni yol ve puan gerekir.

R-03 | Tedarik zinciri: temizlik sırasını bozan servis paketi

Tedarik zinciri saldırganı, **G04** servis paketini değiştirir; paket **G03** USB aktarımıyla yüklenebiliyor kabul edilir (V07/V08). Temizlik ve satışın dışlama/durulama koşulu bozulur, **SF-04** atlanır; V03'teki kimyasal veya sıcak temizleme akışının ürün/erişilebilir dolum yoluna verilmesi ciddi zehirlenme veya yanık doğurabilir. Bağ: Z0→Z3/Z4; C04; A05/A06/W02/W03/F03/F04.

L1: Servis paketini hazırlama/tedarik zincirine yerleştirme ve yerel yükleme zinciri gerekir; USB varlığı tek başına kolay istismar değildir. S3: V03'te kimyasal/sıcak akışın insana ulaşması ciddi fiziksel sonuçtur. E1: Makineye son geçiş fiziksel USB'dir; tedarikçinin internet bağlantısı otomatik E3 yapılmaz.

R-04 | Hedefli: bakım projesi üzerinden yeniden başlama engelinin bozulması

Hedefli saldırgan **G04** bakım aracı/proje dosyasını değiştirir; yerel serviste **G05** üzerinden yüklenen proje SF-03 yeniden başlatma engelini kaldırır (V02/V08). Enerji geri geldiğinde bakım bölgesindeki karıştırıcı çalışabilir; erişen kişi ağır yaralanabilir. Bağ: Z3→Z4; C03; A07/W03/F03/A02/A03.

L1: Hedefe uygun proje bilgisi, dosya değişikliği ve yerel yetkili aktarımın birlikte gerçekleşmesi gerekir. S3: SF-03 bozulduğunda erişilebilir hareket R-01 ile aynı ağır yaralanmayı doğurabilir. E1: Değerlendirilen son erişim yerel bakım bağlantısıdır; R-01'in internet yolu bu senaryoya taşınmaz.

Sıralanmış Risk Register

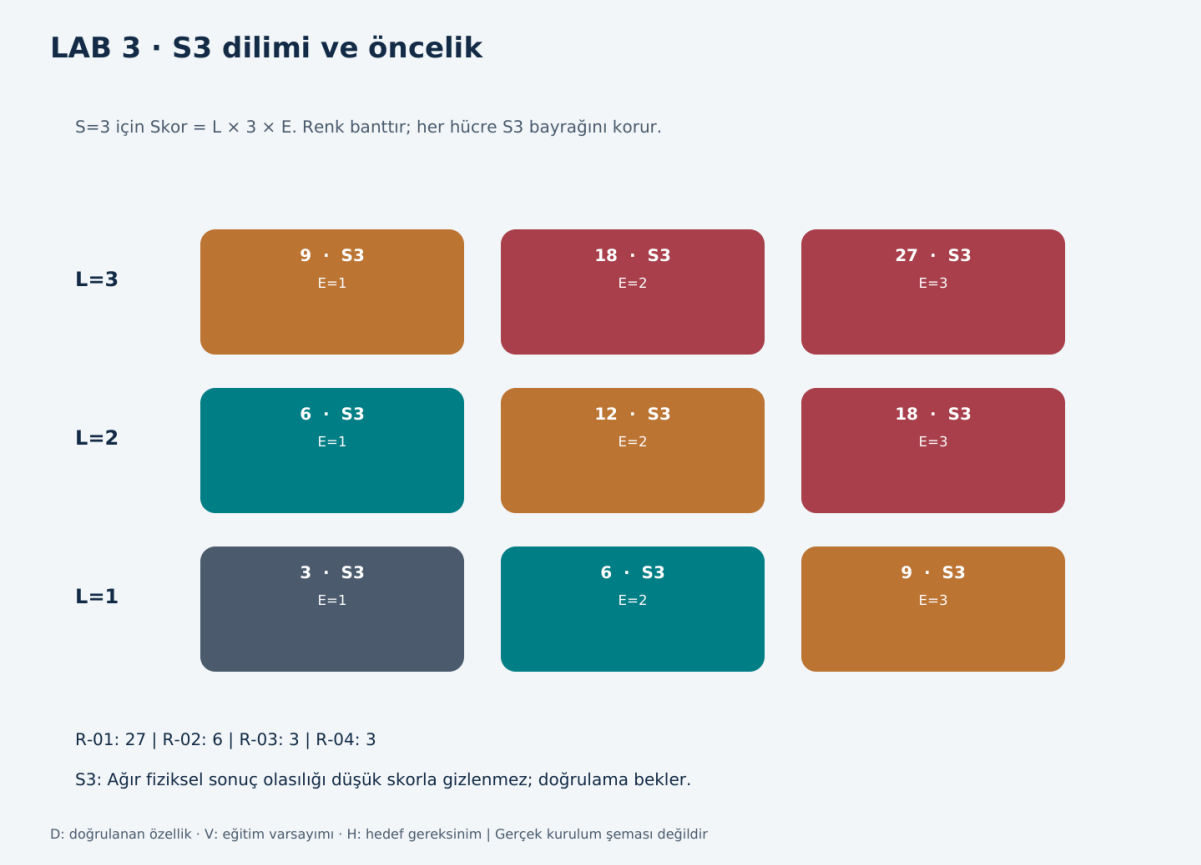
ID	L	S	E	Skor / bant	S3	Öncelik
R-01	3	3	3	27 Kritik	Evet	1
R-02	2	3	1	6 Orta	Evet	2
R-03	1	3	1	3 Düşük	Evet	3
R-04	1	3	1	3 Düşük	Evet	4

R-03/R-04 eşit puanda beraber öncelik grubundadır; tablo sırası idarîdir. İkisi de S3 listesinde açık kalır. Skor dışında veri/üretim kaybı senaryosu örneği, fiziksel zinciri yoksa S1 olarak ayrı yönetilebilir; üç gerekli fiziksel senaryonun yerine geçirilmez.

Yönetim, kanıt ve hedef artık risk

ID	Önerilen işlem	A / R önerisi	Eğitim hedef tarihi	Hedef L/S/E ve koşul
R-01	Kontrolsüz uzak yazmayı kapat; H01/H03, H06/H07	A işletmeci / R OT+servis	25.11.2026	1/3/2=6; erişim kontrolleri doğrulanırsa
R-02	Servis yetkilerini ayır; H02 sıcaklık/satış koruması	A işletmeci / R gıda sorumlusu+OT	24.01.2027	1/3/1=3; yetki denetimi doğrulanırsa
R-03	H04 satış-yıkama dışlaması, H05 güvenilir paket	A işletmeci / R servis+gıda sorumlusu	24.01.2027	1/3/1=3; ölçek tabanı nedeniyle skor değişmeyebilir
R-04	H03 yeniden başlama engeli, H05 proje bütünlüğü	A işletmeci / R servis+emniyet uzmanı	24.01.2027	1/3/1=3; fiziksel doğrulama gereklidir

Roller öneridir; gerçek kişilere görev atanmış değildir. Tarihler dersin 30/90 günlük önerisinden hesaplanmıştır; yakın fiziksel tehlike varsa bu süreler beklenmeden güvenli duruş uygulanır. Mevcut önlemler doğrulanamadı; H kontrollerinin uygulama kanıtı yoktur. Hedef puanlar **gerçek artık risk değildir**. Emniyet bağımsızlığı doğrulansa bile bu kayıtta S3 otomatik S1 yapılmaz; fiziksel zincirin kesildiği kanıt ayrıca kaydedilir. Her risk EP04 kaydına, LAB1 SF'ye, LAB2 kapı/conduit'e ve doğrulama planındaki D01–D05'e bağlıdır.



S3 risk dilimi

Föy soruları

L3-Q1 | En yüksek öncelikli senaryonuz hangisi? Neden?

R-01: Eğitim başlangıcında dışa sürekli açık ve kolay erişilir servis yolu, normal kontrol yazılımındaki koruma koşulunu etkileyerek bakım yapan kişide ağır yaralanmaya uzanabilir.

L3-Q2 | S=3 olup skoru düşük kalan senaryo var mı? Nasıl görünür kılacaksınız?

R-03/R-04 skor 3'tür fakat S3'tür. Ayrı S3 listesi, sorumlu, hedef tarih ve doğrulama kanıtı ile izlenir. R-02'nin orta puanı da S3 yükümlülüğünü kaldırmaz. Bu çalışmada dört kayıt da açık/doğrulama bekliyor.

LAB3 ders notundaki beş tartışma sorusu

L3-T1 | Aynı kapıyı iki farklı profil kullanırsa skor değişir mi?

Profil adı tek başına değiştirmez. Aynı giriş ve kontrol koşulunda L/E tutarlı olmalıdır. Gereken beceri, erişim veya hedef fiziksel işlev değişirse farklı gerekçeyle ayrı kayıt açılır.

L3-T2 | Skoru 27 ama S1 olan senaryo mu, skoru 3 olan S3 mü önce?

Sorudaki ilk sayı aritmetik olarak mümkün değildir: L ve E en fazla 3, S1 ise en yüksek skor 9'dur. Geçerli karşılaştırmada 9/S1 ile 3/S3 arasında fiziksel zarar içeren S3 görünür tutulur; yalnız büyük çarpıma bakılarak bütçe verilmez. Bu, ders notundaki sorunun aynen aktarılmasıyla fark edilen tutarlılık düzeltmesidir.

L3-T3 | Emniyete dokunmayan siber senaryo Register'a girmeli mi?

İşletme etkisi için S1 olarak tutulabilir; emniyet bulgusu diye sunulmaz. Fidye sonrası tehlikeli elle müdahale varsa o ek fiziksel zincir yeni varsayım ve gerekçeyle ayrıca kurulur.

L3-T4 | Tedarikçinin güvenli beyanına ne kadar güvenirsiniz; hangi kanıt gerekir?

Beyan başlangıç bilgisidir. Versiyonlu devre/ağ çizimi, yazma yetkileri, değişiklik kayıtları, cihaz güvenlik belgeleri, paket doğrulaması ve ilgili emniyet test sonuçları gerekir. Bu belgeler bu ödevde firmadan istenmez; bilinmeyenler açık bırakılır.

L3-T5 | Register ne zaman tekrar puanlanmalı?

Yeni zafiyet, firmware/yazılım veya ağ değişikliği, uzaktan erişimin açılması, yeni ödeme/SMS işlevi, arıza/olay, bakımda koruma değişikliği ve varsayımın yanlışlanması durumunda; ayrıca planlı gözden geçirmede.

Ek sorular ve yanıtları

L3-E1 | İnternet bağlantısı hiç yoksa sonuç ne olur?

V05 yanlışlanır; R-01'in bu yolu çıkarılır ve yeni yerel senaryo varsa ayrıca puanlanır. R-02/R-03/R-04 fiziksel erişim ve bakım kabullerine bağlı olarak kalabilir. İnternetsiz cihaz risksiz sayılmaz.

L3-E2 | Temizlik yalnız soğuk suyla yapılıyorsa?

R-03'ün kimyasal/termal sonucu ve S3 gerekçesi geçersizleşir. Gerçek hijyen/bulaşma veya taşma etkisi kendi kanıt ve ölçeğiyle yeniden değerlendirilir; eski puan korunmaz.

L3-E3 | Önlem sonrası skor düşmüyorsa önlem işe yaramaz mı?

Hayır. Üç basamaklı ölçek taban etkisi yaratır; özellikle L1/E1 altına inilmez. Zincirin kesilmesi, test kanıtı ve kalan belirsizlik puandan ayrıca gösterilir.

L3-E4 | En çok tartışılabilecek puan hangisi?

R-02 S3: Gerçek ürün, sıcaklık-süre geçmişi ve tüketici etkisi bilinmez. Koşullu ciddi sonuç açıkça yazılmıştır; olay kanıtı sayılmaz. Bu belirsizlik gıda sorumlusu değerlendirmesiyle azaltılır, uydurma ölçümle kapatılmaz.